

LIVRABLE TECHNIQUE · DIFFUSION RESTREINTE

Rapport d'audit

Application Gateway

Conformité, sécurité et observabilité d'une infrastructure de mise en réseau Azure

CLIENT Distributeur e-commerce — anonymisé	PERIMETRE 2 Application Gateway V2
SOUSCRIPTION Nom-Souscription-Azure — anonymisée	REGION West Europe
DATE D'AUDIT 14/05/2026	AUTEUR Hicham KADIRI

CONFIDENTIEL — DIFFUSION RESTREINTE

Réf. : DK-AGW-AUDIT — v1.0

SECTION 1

L'essentiel, en une page

Exemple travaillé — les chiffres et constats ci-dessous illustrent un cas réel anonymisé. Remplace-les par ton contexte ; conserve la structure et le ton.

À REMEDIER

96 / 131 — 73 %

L'infrastructure tient la charge nominale et l'architecture de base est saine : SKU V2, trois zones, auto-scaling correctement borné. Elle repose toutefois sur deux fragilités qui, le jour d'un incident, se paieront cher — un WAF laissé en mode *Detection* depuis trois mois, et un certificat de production qui arrive à expiration dans vingt-deux jours sans rotation automatisée. Ni l'un ni l'autre n'est visible tant que tout va bien. C'est précisément le genre de dette qui ne se déclare qu'au pire moment.

Ce qui doit bouger en premier

REF.	CONSTAT PRIORITAIRE	CRITICITE
S4	WAF Policy en mode Detection sur l'AGW frontale de production — le trafic malveillant est journalisé, jamais bloqué.	CRITIQUE
C2	Certificat star.client.fr à 22 jours de l'expiration, uploadé manuellement, sans référence Key Vault ni rotation.	CRITIQUE
O1	Ruleset managé encore en CRS 3.2 (version N-2) — migration vers DRS 2.2 recommandée avant le prochain pic de trafic.	ÉLEVE

Le détail item par item suit en section 3. Le plan de remédiation chiffré, avec effort et échéances, est en section 4 — pensé pour être repris tel quel dans un planning d'équipe.

SECTION 2

Le diagnostic, chiffré

Le score agrège 47 points de contrôle répartis en huit domaines, pondérés par criticité. Un item critique non conforme pèse davantage qu'un item faible : la note ne récompense pas le volume de cases cochées, elle reflète l'exposition réelle au risque.

CRITIQUES	ÉLÈVES	MOYENS	FAIBLES
2 / 13	4 / 17	3 / 11	1 / 6

Lecture par domaine

DOMAINE	CONFORMES	ÉCARTS	PIRE ITEM
1 · Architecture	5 / 5	0	—
2 · Réseau & NSG	6 / 7	1	MOYEN
3 · TLS & chiffrement	4 / 6	2	ÉLEVE
4 · WAF & sécurité applicative	3 / 6	3	CRITIQUE
5 · Backends & probes	5 / 6	1	ÉLEVE
6 · Certificats	2 / 4	2	CRITIQUE
7 · Observabilité	4 / 7	3	ÉLEVE
8 · Gouvernance & tags	5 / 6	1	MOYEN

Méthode reproductible : chaque item est vérifiable par une commande Azure CLI, une requête KQL ou un script PowerShell de l'Annexe B. Un second consultant rejoue les contrôles et retrouve le même score — c'est la condition pour qu'un audit soit un constat, et non une opinion.

SECTION 3

Constats — du symptôme au traitement

Chaque écart est présenté comme on présente un cas : ce qu'on observe, ce que ça coûte si on ne fait rien, et le geste à poser. Seuls les écarts critiques et élevés sont détaillés ici ; les items moyens et faibles figurent dans le tableau de l'Annexe E jointe.

CRITIQUE S4 · réf. Pathologie P9 **WAF en mode Detection prolongé****CONSTAT**

La WAF Policy attachée à l'AGW frontale est en mode Detection. La date de dernière modification remonte à trois mois : le mode n'a jamais été basculé après la phase de tuning initiale.

CONSEQUENCE

Toute requête malveillante est journalisée mais **transmise au backend**. La protection est nominale, pas effective : en cas d'attaque applicative, le WAF ne bloque rien. Exposition directe pour une plateforme qui traite des paiements.

TRAITEMENT

Basculer en Prevention après revue d'une semaine de logs ApplicationGatewayFirewallLog pour écarter les faux positifs. Renvoi : chapitre 9 §tuning, et script Audit-AGW-Health.ps1 (point 4).

SUIVI

Contrôle automatisé du mode WAF intégré au pipeline d'audit hebdomadaire ; alerte si retour en Detection.

CRITIQUE C2 · réf. Pathologie P13 **Certificat sans rotation, expiration imminente****CONSTAT**

Le certificat star.client.fr expire dans 22 jours. Il a été uploadé manuellement : aucune référence KeyVaultSecretId, donc aucune rotation automatique possible.

CONSEQUENCE

À l'expiration, l'AGW présente un certificat invalide : erreur navigateur sur tout le trafic HTTPS, indisponibilité de fait. Le scénario classique de la panne du vendredi soir, parce que personne n'avait l'échéance en tête.

TRAITEMENT

Migrer le certificat dans Key Vault et référencer via KeyVaultSecretId + identité managée. L'AGW recharge alors automatiquement les renouvellements. Renvoi : Annexe A (bloc sslCertificates) et script Test-AGW-CertificateExpiry.ps1.

SUIVI

Audit d'expiration hebdomadaire, seuil d'alerte à 45 jours.

ÉLEVÉ O1 · réf. Pathologie P8 **Ruleset managé en version N-2****CONSTAT**

Le WAF tourne sur CRS 3.2. Azure maintient les trois dernières versions (N / N-1 / N-2) ; CRS 3.2 est aujourd'hui en N-2, DRS 2.2 étant la version recommandée.

CONSEQUENCE

Surface de détection en retard sur les signatures récentes. À terme, sortie du support : migration forcée, sans fenêtre choisie.

TRAITEMENT

Planifier la montée vers DRS 2.2 hors période de pic, avec une semaine d'observation en Detection sur la nouvelle version avant bascule. Renvoi : chapitre 9.

SUIVI

Revue trimestrielle de la version de ruleset, alignée sur le calendrier Microsoft.

SECTION 4

Ordonnance — le plan de remédiation

Priorisé par exposition, pas par facilité. L'effort est en jours-homme, l'échéance relative à la date d'audit. La colonne renvoi pointe l'artefact technique du livre qui porte la solution.

REF.	ACTION	EFFORT	RESPONSABLE	ÉCHEANCE	RENOI
C2	Migration du certificat vers Key Vault + identité managée	0,5 j-h	Julien (CI/CD)	Sous 7 j	Anx. A
S4	Revue des faux positifs puis bascule WAF en Prévention	1 j-h	Stéphanie	Sous 7 j	Ch.9
O1	Montée du ruleset managé vers DRS 2.2	1 j-h	Stéphanie	< 3 mois	Ch.9
B7	Resserrement des custom probes (chemin santé réel)	0,5 j-h	Julien	< 3 mois	Ch.17
B7	Tiering des logs : archive au-delà de 30 j	1 j-h	Stéphanie	< 6 mois	Ch.14
G3	Complétion des tags de gouvernance manquants	0,25 j-h	Julien	< 6 mois	Ch.13

Total effort estimé : 4,75 jours-homme. Les deux actions critiques (C2, S4) représentent à elles seules l'essentiel du risque résiduel et tiennent en une journée et demie : c'est là que doit aller l'attention de la semaine qui vient.

SECTION 5

Suivi — quand réausculter

Un audit est une photographie. Sa valeur tient à la cadence des suivants. Le rythme proposé :

CONTROLE	CADENCE	AUTOMATISATION
Bilan de santé 12 points	Hebdomadaire	Export-AGW-AuditReport.ps1
Expiration des certificats	Hebdomadaire	Alerte à 45 jours
Version du ruleset managé	Trimestrielle	Revue manuelle
Audit complet 47 items	Semestrielle / post-incident	Présent référentiel